

PASSIVE ASSESSMENT

API Security Findings Report

Northwind Payments — a fictional estate. Every figure below was exported from a real gateway run, not written by hand.

What we found

2

CRITICAL FINDINGS

4

CONFIRMED DATA LEAKS

6

APIS DISCOVERED

3

WITH NO AUTH AT ALL

AEGIS ran in front of the API in passive mode: it inspected and recorded, and blocked nothing. In that window it discovered **6 live endpoints**, of which **3 enforce no authentication, rate limiting or firewall at all**. Two of them return customer payment-card and email data to callers presenting no credential whatsoever.

Separately, the gateway observed **4 confirmed cases** of one authenticated user reading another user's records — not inferred from volume, but confirmed by comparing the owner id in each response body against the caller's verified identity. This is the class of flaw a signature firewall cannot detect, because the requests are syntactically perfect.

Critical findings

Sensitive data exposed to unauthenticated callers

CRITICAL · API3:2023

`GET /api/v1/customers/{id}` risk 75

endpoint returned PCI/PII (credit_card, email) on 6 response(s) while 6 request(s) arrived without authentication

Sensitive data exposed to unauthenticated callers

CRITICAL · API3:2023

`GET /internal/reports/export` risk 75

endpoint returned PCI/PII (credit_card, email) on 2 response(s) while 2 request(s) arrived without authentication

Broken object level authorization — confirmed

CRITICAL · API1:2023

GET /api/v1/orders/{id} 4 objects read by a caller who does not own them
consumer 'bob.kessler@example.com' GET object '1005' (/api/v1/orders/{id}) owned by '12' (from response body) — confirmed IDOR (BOLA)

Object enumeration by a single consumer

CRITICAL · API1:2023

consumer 'bob.kessler@example.com' accessed 5 distinct object IDs on 'GET /api/v1/orders/{id}' (hard ceiling 4)

API inventory and posture

Every endpoint below was discovered from traffic — nothing was declared in advance.
Unprotected means none of authentication, rate limiting or firewall applies to it.

One caveat stated rather than hidden: this assessment ran in passive mode, so AEGIS enforced nothing while it watched. The *partial* and *protected* labels therefore describe what was active during the assessment, not the ceiling of what the estate could enforce.
Unprotected is unaffected — an endpoint with no authentication has none either way, which is why the summary leads with that number.

ENDPOINT	POSTURE	REQ	ANON	PII	RESPONSES	RISK
GET /api/v1/customers/{id}	UNPROTECTED	6	6	6		75
GET /internal/reports/export	UNPROTECTED	2	2	2		75
GET /health	UNPROTECTED	2	2	0		50
GET /api/v1/invoices/{id}	PARTIAL	4	0	0		25
GET /api/v1/orders/{id}	PARTIAL	9	0	9		20
POST /api/v1/payments	PARTIAL	5	0	0		10

Who is calling what

Consumer identity is taken from the verified JWT where one is present, and falls back to source address where none is.

CONSUMER	IDENTIFIED BY	REQUESTS	ENDPOINTS
alice.renner@example.com	verified token	11	3

127.0.0.1	source address (no credential)	10	3
bob.kessler@example.com	verified token	7	1

Regulatory mapping

The findings above map onto 6 controls across OWASP API Top 10, NIS2 and ISO/IEC 27001:2022. This is a mapping aid for an audit conversation, not a certification.

FRAMEWORK	CONTROL	TITLE	SEVERITY	ISSUES
OWASP API Top 10	API1:2023	Broken Object Level Authorization	CRITICAL	2
OWASP API Top 10	API3:2023	Excessive data exposure	CRITICAL	2
NIS2	Art. 21(2)(h)	Cryptography and encryption of data	CRITICAL	2
NIS2	Art. 21(2)(i)	Access control policies	CRITICAL	2
ISO 27001:2022	A.5.34	Privacy and protection of PII	CRITICAL	2
ISO 27001:2022	A.8.3	Information access restriction	CRITICAL	2

How this report was produced

This is a sample. The API behind it — Northwind Payments — is fictional and deliberately flawed, and the customer records in it are synthetic (reserved `example.com` addresses and standard test card numbers). No real company's data appears anywhere in this document.

The findings themselves are not mocked up. A real AEGIS instance ran in front of that API, ordinary traffic was driven through it, and every number, endpoint, consumer and finding above was exported from what the gateway actually observed. The generator is committed at `demo/sample-report/` and reproduces this document end to end.

On a real engagement the same output describes your estate instead: AEGIS is deployed in passive mode, blocks nothing, and after roughly a week hands back this report. The deployment carries no production risk — no request is modified, no response is altered, and no control fails closed.